

Information Security Policy

Organization: Ouro e Prata Elétrica — CNPJ 43.103.402/0001-24

Product: Sistema Vargas — multi-tenant ERP and point-of-sale platform (www.sistemavargas.com.br)

Document owner: Silvano Nunes Vargas, Owner — acting Information Security Officer

Version: 1.0

Effective date: 2 August 2026

Next review: 12 months from the effective date, or after any Severity 1 incident

Before this document is submitted to any partner, the person named above must fill in every bracketed field, date it, and sign it. An unsigned, undated policy is what a reviewer reads as "template downloaded, not adopted."

1. Purpose and scope

This policy defines how Ouro e Prata Elétrica protects the information entrusted to it — its own business data, the data of the merchants who use Sistema Vargas, and the data received from commerce platforms that the product integrates with (TikTok Shop, Shopee, Mercado Livre, and the Brazilian tax authority through licensed fiscal providers).

It applies to:

- every person with access to production systems, whether employee, contractor, or founder;
- every environment where merchant or platform data is stored or processed — application hosting, the managed database, object storage, and the local point-of-sale terminals installed at merchant sites;
- every third-party service that processes data on the organization's behalf.

Compliance is mandatory. Access is granted on acceptance of this policy and is withdrawn on violation.

2. Roles and responsibilities

Role	Responsibility
Information Security Officer	Owns this policy, approves access, leads incident response, runs the access review
Engineering	Implements controls, reviews changes, applies security patches
All personnel	Follow this policy, report suspected incidents immediately

The organization is small. Where a control below names a role, the named individual holds it personally; there is no security team to defer to.

3. Data classification

Class	Examples	Handling rule
Restricted	Platform API credentials and OAuth tokens, database service keys, digital tax certificates (A1), password hashes	Never in source control, never in logs, never in a support channel. Encrypted at rest and in transit. Access limited to the Information Security Officer.
Confidential	Merchant customer records (name, CPF/CNPJ, address, phone), order and payment records, product cost and margin	Accessible only to authenticated users of the tenant that owns the data. Never shared across tenants.
Internal	Product catalogue, stock levels, marketplace listings	Accessible to authenticated users of the owning tenant.
Public	Marketing site content	No restriction.

Data received from a commerce platform (orders, buyer contact details, shipping addresses) is classified **Confidential** at minimum, and is used solely to fulfil the merchant's orders — never for marketing, resale, profiling, or model training.

4. Access control

- **Least privilege.** Every account receives the minimum access required for its function. Access is by role, not by exception.
- **Role-based access control.** The application enforces six fixed roles — admin, gerente (manager), financeiro (finance), estoque (stock), vendas (sales), leitura (read-only) — mapped to a fixed permission matrix. The matrix is defined in a single source file and cannot be altered from the user interface, which removes an entire class of misconfiguration.
- **Server-side enforcement.** Permission is verified on the server on every privileged request. Hiding a control in the interface is never accepted as an access control by itself.
- **Tenant isolation.** Every record carries the owning company. Queries are scoped to the authenticated user's company. Cross-company visibility exists only where an administrator has explicitly created a partnership between two companies under the same account owner, and never between different customers of the platform.
- **Database-level authorization.** Row Level Security is enforced in the database on tables holding credentials, integration settings, order history, and audit records, so that an application-layer mistake alone is not sufficient to expose them.
- **Separation of privilege.** The service key that bypasses database authorization is used only in server-side code, is never exposed to a browser, and is never present in the client bundle.
- **Multi-factor authentication** is required for every administrative account — the hosting provider, the database provider, the source code repository, the domain registrar, and every commerce platform developer console.

- **Access review.** The Information Security Officer reviews all production and third-party access **quarterly**, and revokes anything no longer required.
- **Revocation.** Access is removed on the day a person's engagement ends. Blocking a user account terminates the session at the next request, not at the next login.

5. Authentication

- User authentication is delegated to a managed identity provider. Passwords are never stored in plaintext and never handled by application code; they are stored as salted bcrypt hashes by the identity provider.
- Point-of-sale operator credentials are verified inside the database by a dedicated function that never returns the stored hash to the client.
- Sessions are carried in HTTP-only cookies over TLS. Every dashboard and point-of-sale route requires a valid session; unauthenticated requests are redirected to the login page before any data is read.
- Temporary support access to a customer account requires a written justification, expires automatically after two hours, is recorded in the audit log, and is disclosed to the customer with a banner on their next sign-in.

6. Encryption

- **In transit.** All traffic is HTTPS. TLS 1.2 is the minimum accepted version. Strict-Transport-Security is set with a one-year maximum age including subdomains, so browsers refuse plaintext connections to the domain. Certificates are issued and renewed automatically by the hosting provider.
- **At rest.** The managed database and object storage encrypt data at rest using the provider's disk-level AES-256 encryption. Backups are encrypted by the same mechanism.
- **Secrets.** Platform API keys, OAuth tokens, and database service keys are held as environment variables in the hosting provider's encrypted configuration store. They are excluded from source control by repository configuration (.env* is ignored) and are never written to application logs.
- **Tax certificates.** Digital certificates (A1) used for fiscal document issuance are transmitted directly to the licensed fiscal provider over TLS and are not retained in application storage.

7. Network and infrastructure security

- The application runs on a managed serverless hosting platform. There are no self-managed servers, no open SSH ports, and no publicly reachable administrative consoles under the organization's operation.
- The database is a managed PostgreSQL service. It is reachable only over TLS and is protected by the authorization model described in section 4 — including for requests presenting the public client key, which carries no privileges beyond what policy explicitly grants.
- The following response headers are applied to every route: Strict-Transport-Security, X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN,

Content-Security-Policy: frame-ancestors 'self', Referrer-Policy: strict-origin-when-cross-origin, and a Permissions-Policy denying camera, microphone, geolocation, and payment APIs. The server technology banner is suppressed.

- Denial-of-service protection, TLS termination, and edge filtering are provided by the hosting platform.

8. Secure development

- All source code is held in a private repository with access limited to named individuals, each protected by multi-factor authentication.
- Changes are deployed through the hosting provider's build pipeline. A build that fails type-checking or compilation is not deployed.
- Secrets are never committed. The repository ignores environment files by configuration.
- Dependencies are obtained from the public package registry with a committed lockfile. Advisories are reviewed and security updates applied on the schedule in section 10.
- Database schema changes are applied as reviewed, version-controlled migration scripts.

9. Logging and audit

- Privileged actions — user invitation, role change, account block, support access, fiscal document issuance, marketplace mapping changes, order stage changes — are written to an immutable audit table recording the actor, the action, the affected record, the previous value, the new value, and the timestamp.
- Stock movements are recorded as an append-only ledger; corrections are entered as new compensating entries, never by editing or deleting history.
- Application and platform logs are retained by the hosting provider for its standard retention period.
- Audit records are retained for a minimum of **12 months**.

10. Vulnerability and patch management

- Dependency advisories are reviewed at least **monthly**.
- Remediation targets from the time a fix is available:

Severity	Target
Critical	7 days
High	30 days
Medium	90 days
Low	next scheduled maintenance

- Platform-level patching of the hosting runtime and the database engine is performed by the respective managed providers.

11. Incident response

An **incident** is any suspected or confirmed unauthorized access to, disclosure of, alteration of, or loss of data, or any compromise of a credential.

Anyone who suspects an incident reports it immediately to Silvano Nunes Vargas at security@sistemavargas.com.br / +55 21 98294-9060. There is no penalty for a report that turns out to be a false alarm; there is one for staying silent.

Phase	Action	Target
1. Detect and record	Log the report with time, reporter, and what was observed	Immediately
2. Contain	Revoke or rotate affected credentials, block affected accounts, disable the affected integration	Within 4 hours of confirmation
3. Assess	Determine what data, whose data, and how much	Within 24 hours
4. Notify	Notify affected merchants, and any commerce platform whose data or credentials are involved, via that platform's designated security channel	Within 24 hours of confirming platform data or credentials are affected
5. Notify authorities	Notify the ANPD and affected data subjects where LGPD Art. 48 requires it	Within the statutory deadline
6. Recover	Restore service from a known-good state	As fast as safely possible
7. Review	Written post-incident record: what happened, root cause, what changed so it cannot recur	Within 10 business days

Credential handling on suspected exposure follows a risk assessment, not a blanket rule. The assessment weighs the harm an attacker could do with the specific credential against the operational cost of rotating it. Credentials capable of producing legally binding documents in the organization's name — the fiscal issuance token above all — are rotated without further deliberation. For credentials whose worst case is commercial rather than legal, the Information Security Officer records the decision, the reasoning, and the compensating control.

The organization states plainly that this is weaker than unconditional rotation. It is written this way because it is what the organization actually does, and a policy that describes an aspiration is worth nothing to the partner relying on it.

12. Backup and continuity

- The managed database provider performs automated backups on the schedule of the organization's subscription tier, with the provider's point-in-time recovery where available.
- Restore capability is tested at least **annually**, and the test is recorded.
- Recovery objectives: **RPO 24 hours, RTO 24 hours**.
- Point-of-sale terminals operate against a local database and continue selling during a connectivity outage, synchronizing when the connection returns.

13. Third-party management

Services that process data on the organization's behalf:

Provider	Purpose	Data
Application hosting provider	Runs the web application	All application traffic
Managed database provider	Database, authentication, object storage	All merchant data
Licensed fiscal providers	Issues Brazilian fiscal documents	Sale, customer, and tax data required by law
Messaging provider	WhatsApp notifications to merchants and their customers	Phone number, order reference
Payment provider	Subscription billing	Subscriber billing data
AI content provider	Optional generation of marketplace listing text	Product catalogue text only — no customer data

Before engaging any new processor, the Information Security Officer confirms it offers encryption in transit and at rest, documented access control, and an incident notification commitment. Customer personal data is never sent to a provider that has not been assessed.

14. Data retention and deletion

- Merchant business records are retained while the account is active, and for the period Brazilian tax and commercial law requires thereafter.
- Data received from a commerce platform is retained only as long as needed to fulfil the merchant's orders and to meet legal record-keeping obligations.
- **On termination of a platform integration, or on the platform's request, all credentials for that platform are revoked and deleted, and the data received from it is deleted within 30 days**, except records the organization is legally required to keep, which are isolated and not processed further.
- Deletion requests from data subjects under LGPD are actioned within the statutory deadline.

15. Endpoint and personnel security

- Devices used to access production are protected by full-disk encryption, a screen lock, and current operating system security updates.
- Production credentials are held in a password manager, never in a plaintext file, a spreadsheet, or a message.
- Personnel are briefed on this policy on engagement and annually thereafter, covering phishing, credential handling, and incident reporting.
- Physical security of the hosting infrastructure is the responsibility of the managed providers, which operate in certified data centres.

16. Platform data commitments

Regarding data received from any commerce platform, the organization commits that it:

- uses the data **only** to provide the merchant with order fulfilment, stock, and accounting functions inside the merchant's own account;
- does **not** sell, rent, license, or share the data with any third party other than the processors listed in section 13, and only as needed to deliver the service;
- does **not** use the data for advertising, audience building, or training machine-learning models;
- keeps each merchant's data segregated from every other merchant's;
- requests the minimum API scopes required for the features it offers;
- deletes the data on request, or on termination, per section 14.

17. Enforcement and review

Violation of this policy may result in immediate withdrawal of access and termination of engagement. This policy is reviewed at least annually and after any Severity 1 incident, by the Information Security Officer.

Adopted by:

Name: _____

Title: _____

Signature: _____ Date: ____ / ____ / ____